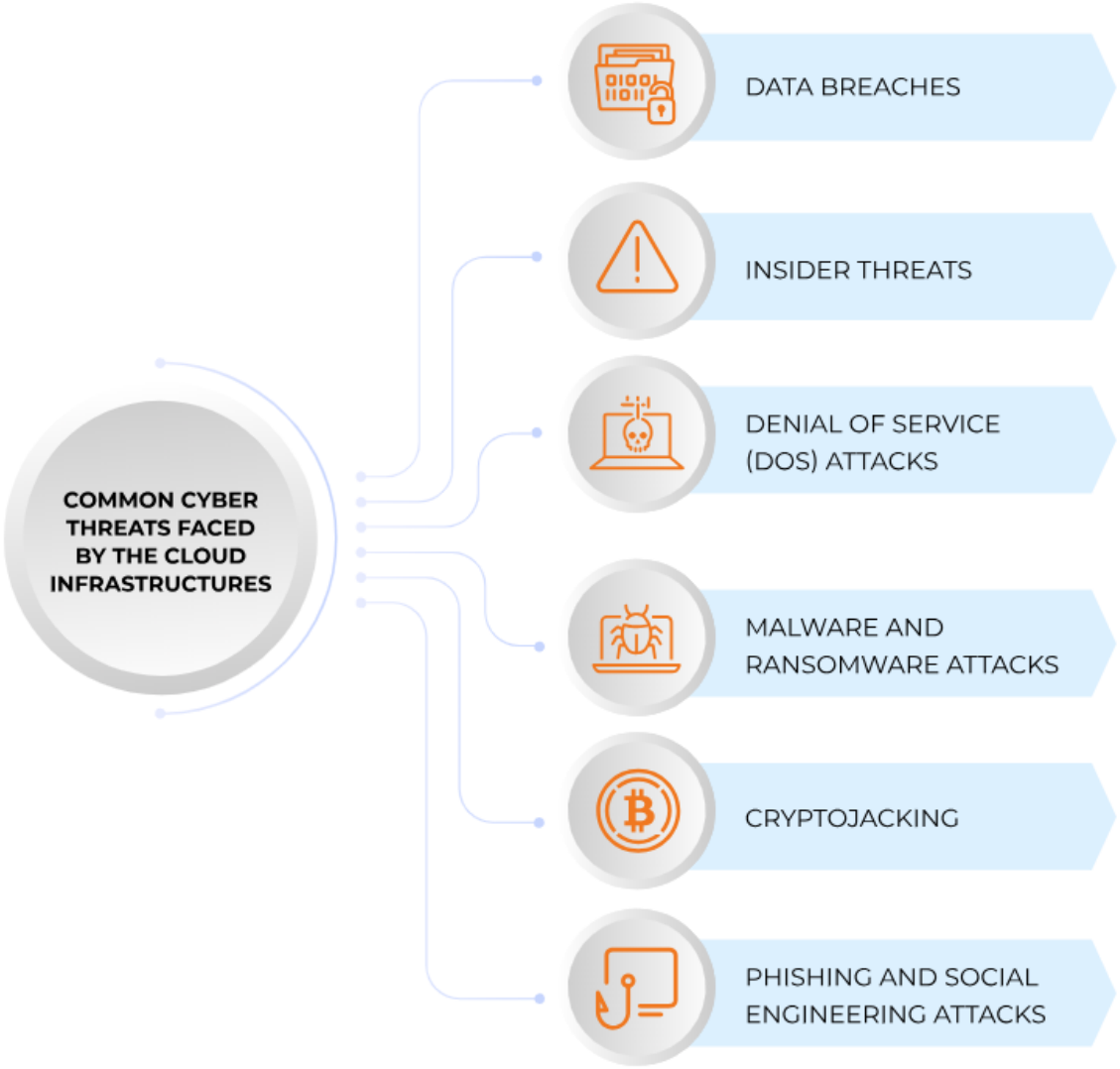
Fundamentals of Cloud Security

Dr Mukti Padhya

Assistant Professor

School of Cyber Security and Digital Forensics, NFSU

Why Cloud Security?



Why Cloud Security?

Hackers accessed **Uber's** cloud-based storage and obtained personal data of 57 million users and drivers. Uber initially failed to report the breach.

•CAM4—2020

CAM4 is an adult live streaming website that fell victim to a cloud cyber attack in March 2020 that exposed 10.8 billion sensitive entries amounting to 7 TB of data. The leaked database included location details, email addresses, IP addresses, payment logs, usernames and more.

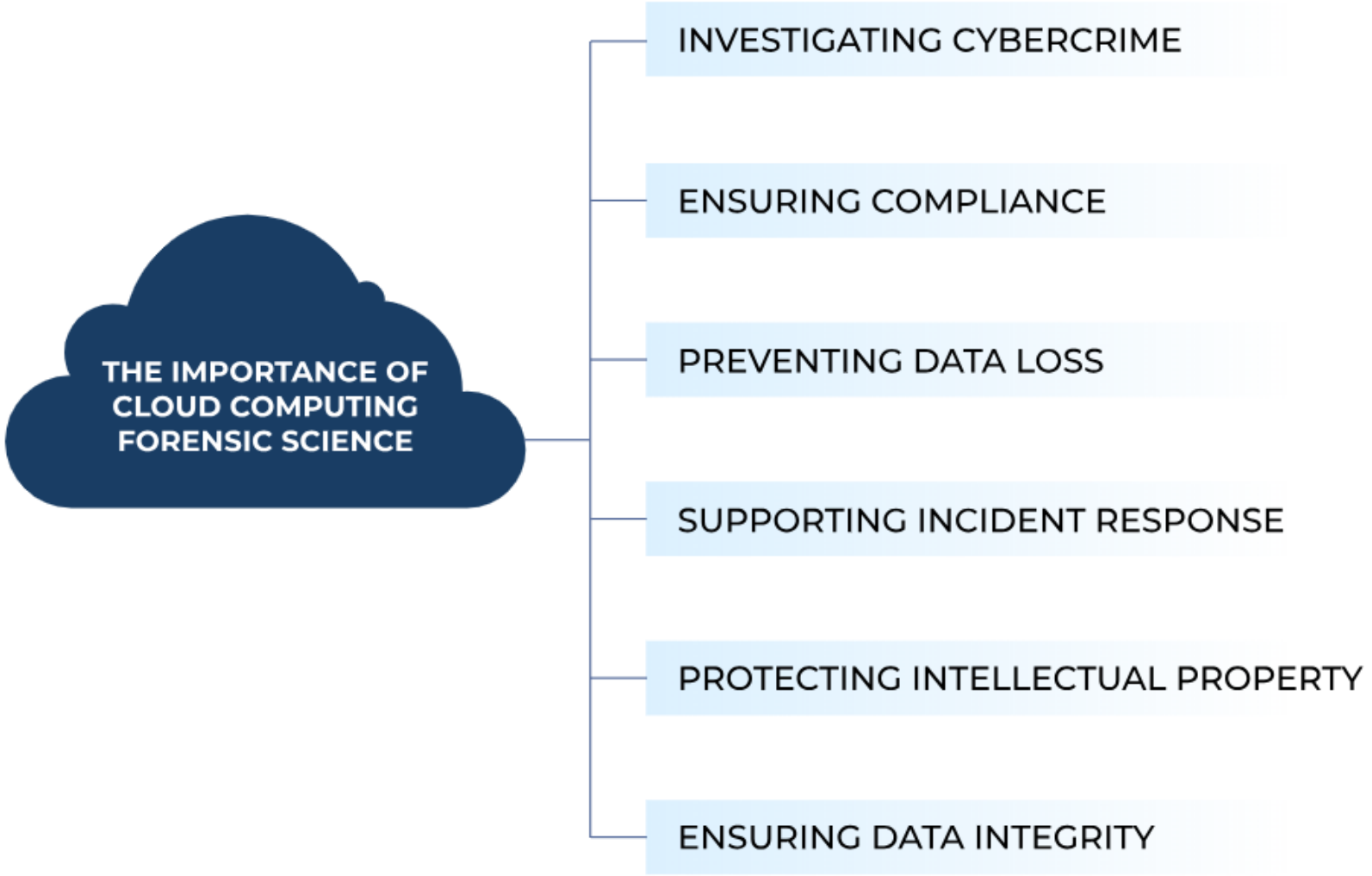
Abuse of Cloud Services - use cheap cloud services to arrange DoS and brute force attacks. Bryan and Anderson arranged a DoS using Amazon's EC2 cloud infrastructure in 2010, by spending only $6 to rent virtual services.

Facebook exposed over 540 million records through unsecured cloud storage, including data such as user comments, likes, and reactions, making it vulnerable to external access.

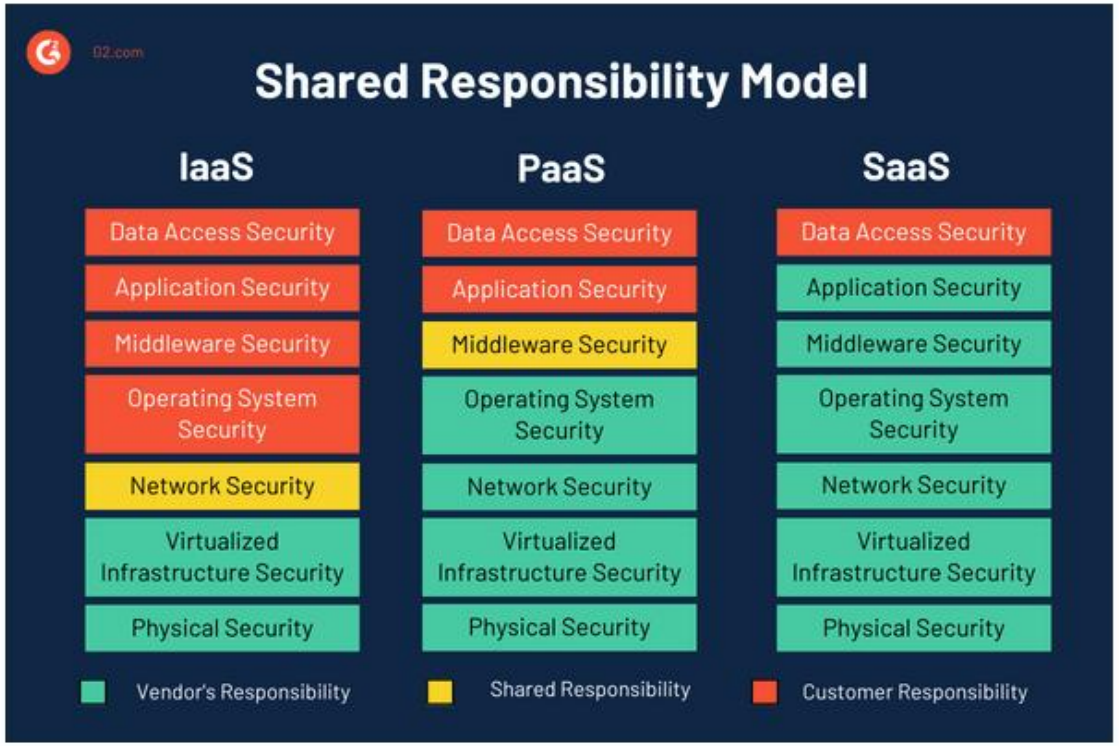
•Advanced Info Service (AIS)—2020

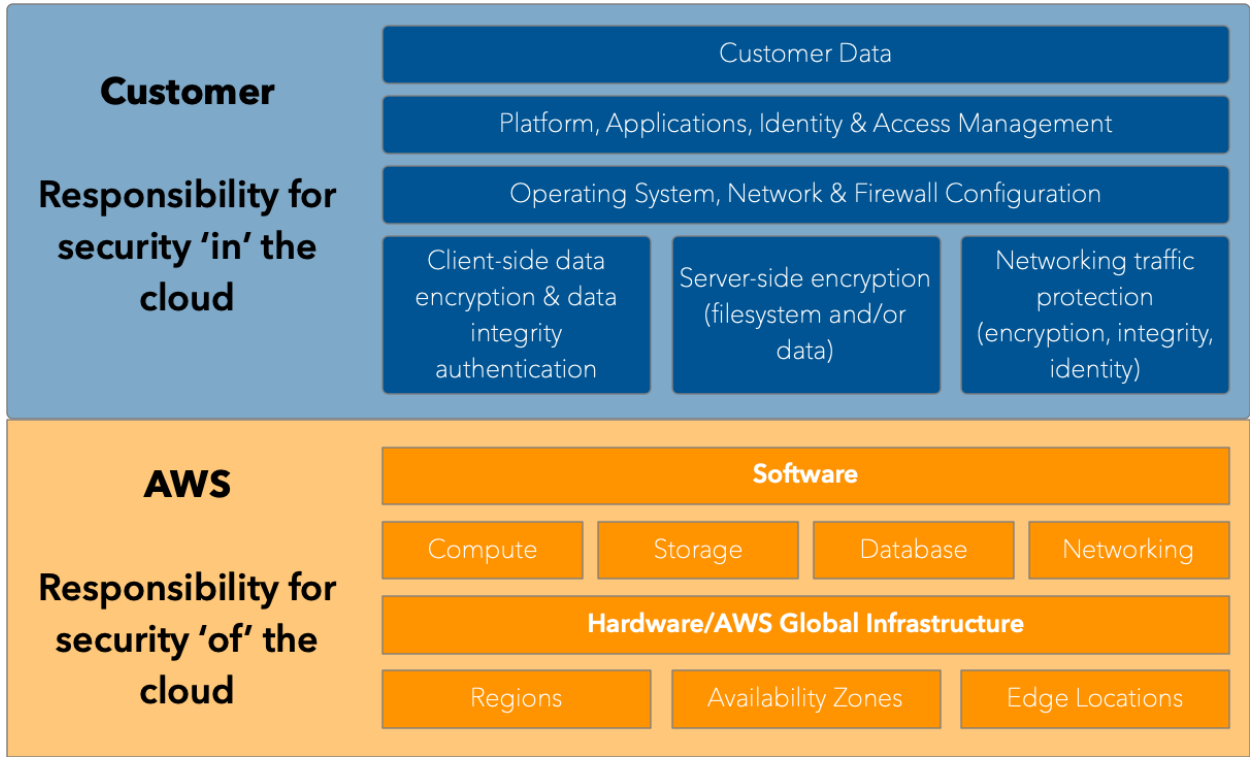
The AIS data breach was discovered by cybersecurity researcher Justin Paine when browsing BinaryEdge and Shodan. According to Paine, the leaked database included 8.3 billion network flow logs and DNS query logs of AWN customers of the Thailand-based telecommunications company.

Why Cloud Security?

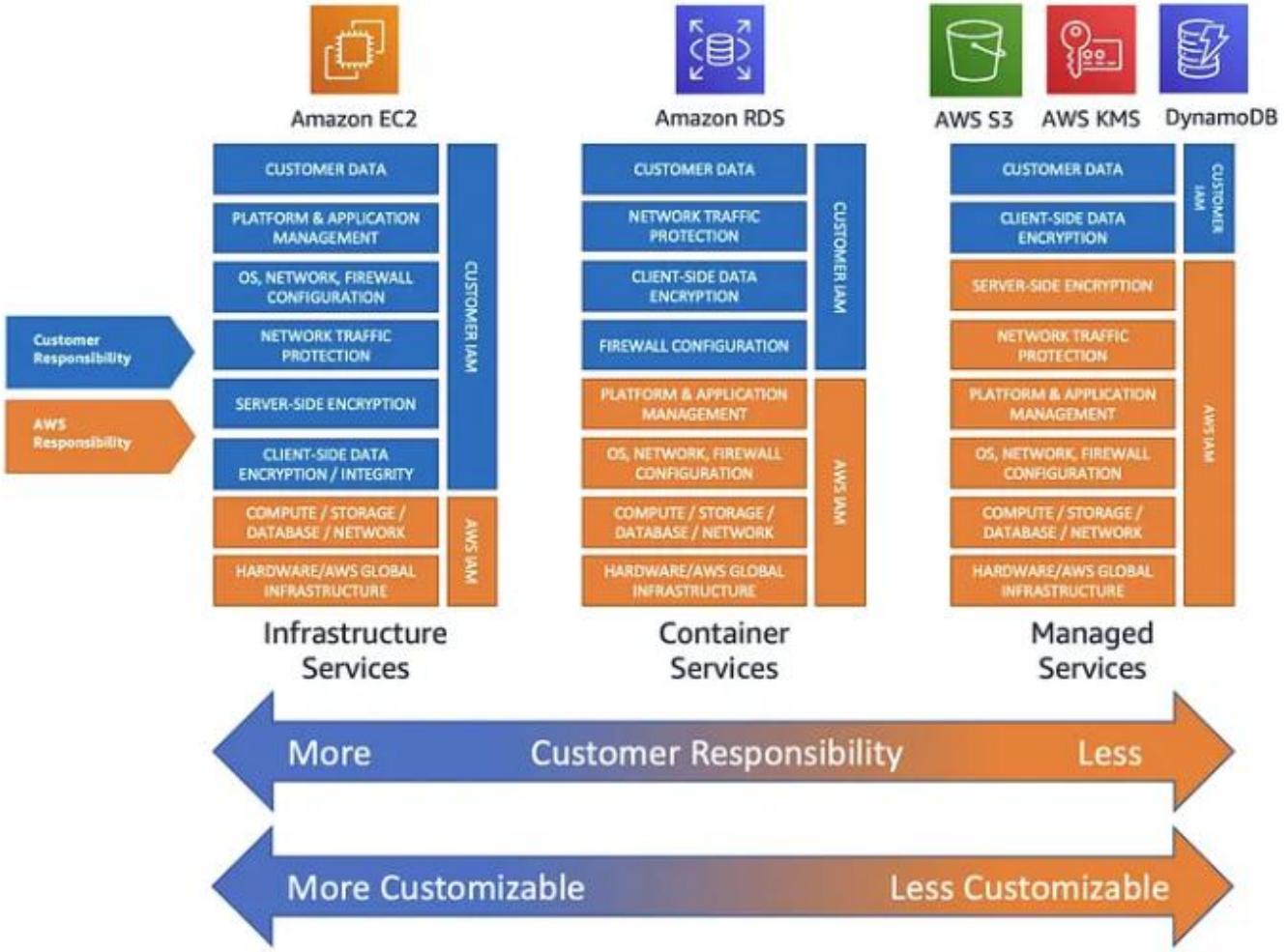


Shared Responsibility Model





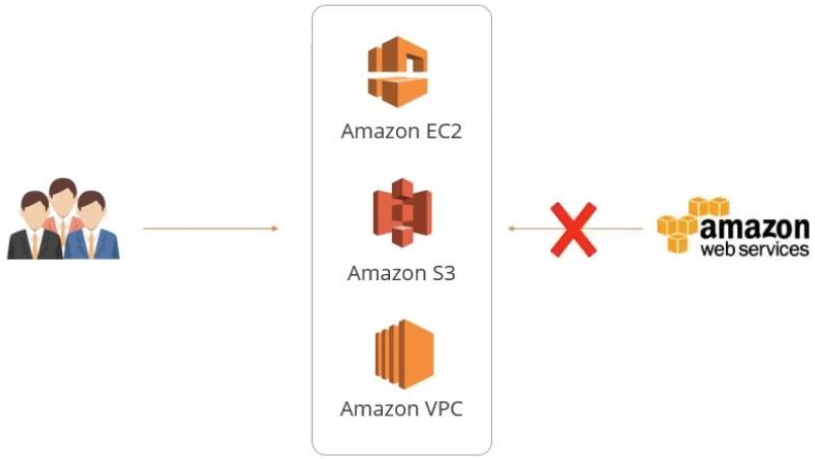
Shared Responsibility Model



Shared Responsibility Model

Infrastructure as a Service (IAAS)

EC2, S3, and VPC are completely under customer control and you have to perform all the security configuration and management tasks.



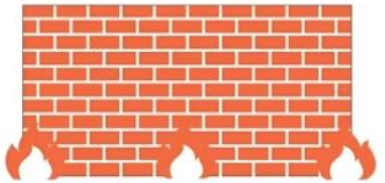
Network

AWS protects against DDoS, Man in the middle, IP spoofing, port scanning, and packet sniffing.



Security Groups



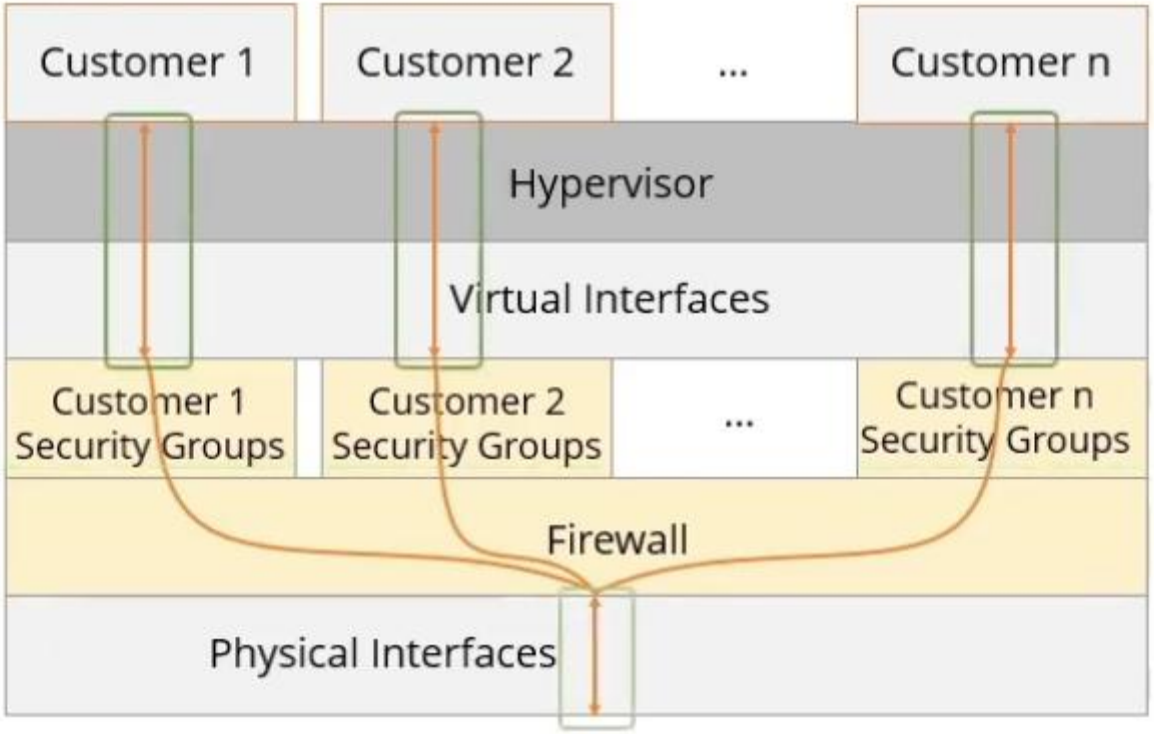


host based firewall infrastructure





Network Seggregation



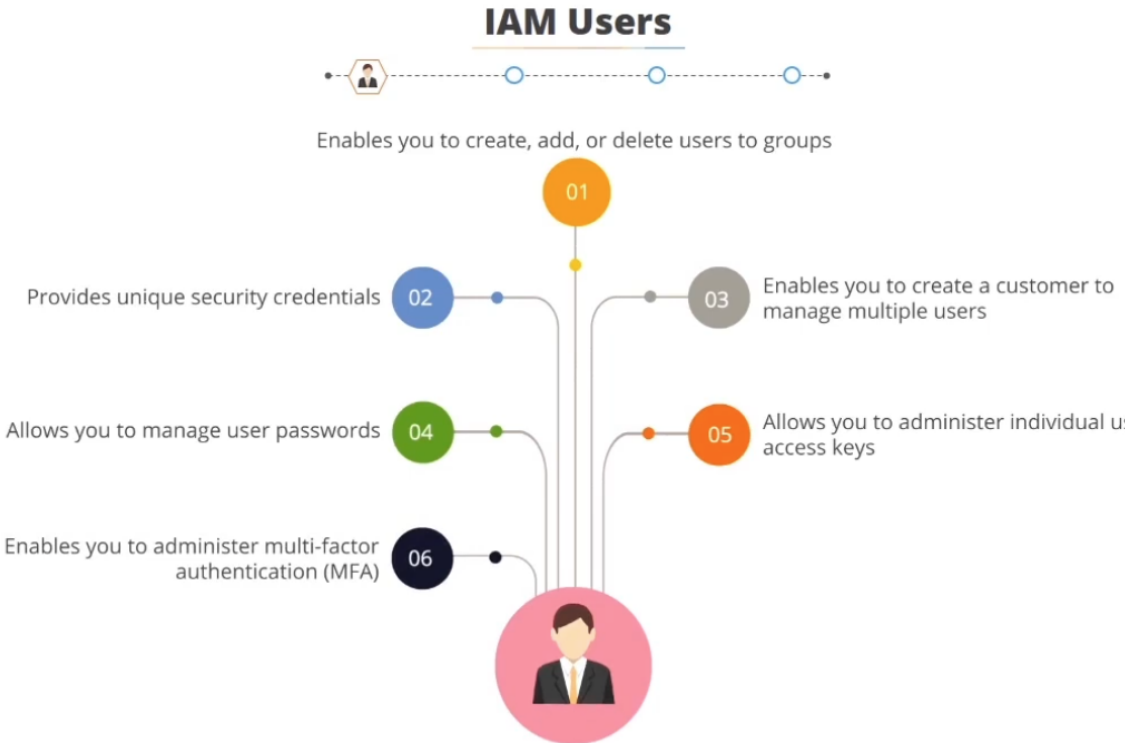

How secure should you make your application?

How to secure your resources on Cloud?

Zero Trust Environment

Secure Your Network	Secure your Data	Secure your Infrastructure
• VPC • Direct Connect	• KMS • Encryption	• IAM – Access Keys • MFA • Security Audit

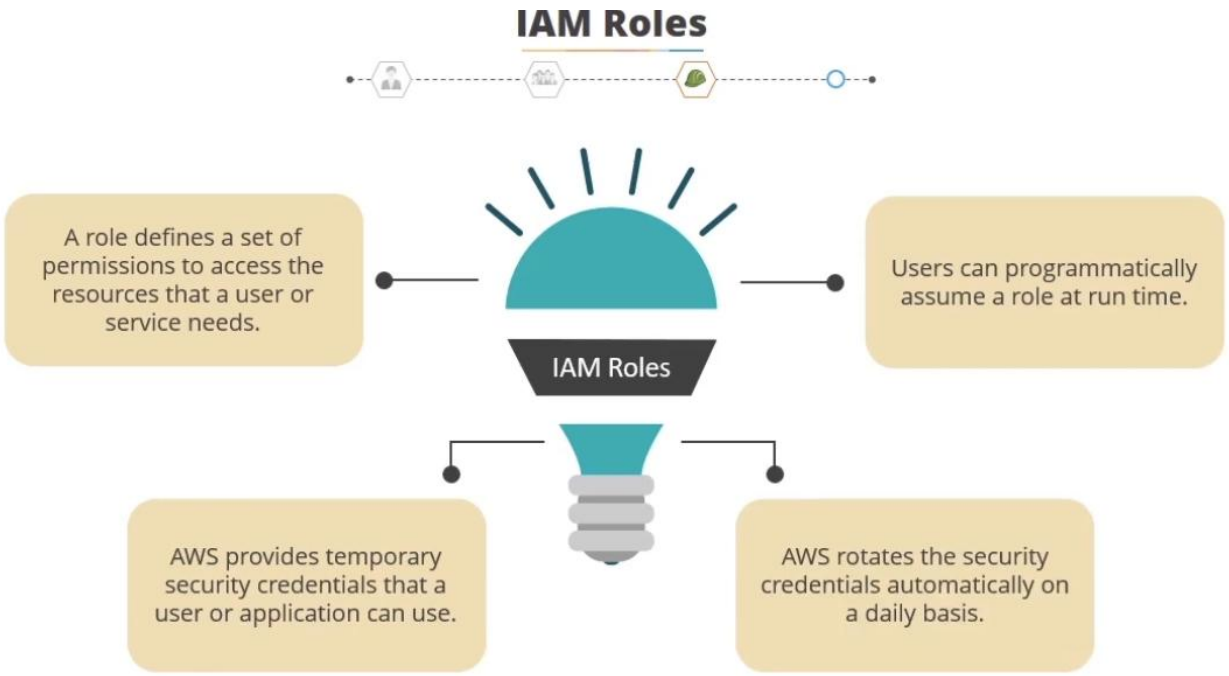
IAM : Identity Authentication Management



IAM User Permissions

- A new IAM user by default, is not authorized to perform any AWS actions.
- Assign administrative permissions to a few users who in turn create and manage other IAM users.
- Use a "least privilege" policy when assigning permissions, to:
  - [ ] Reduce the chances of making mistakes.
  - [ ] Increase access permissions as and when required.

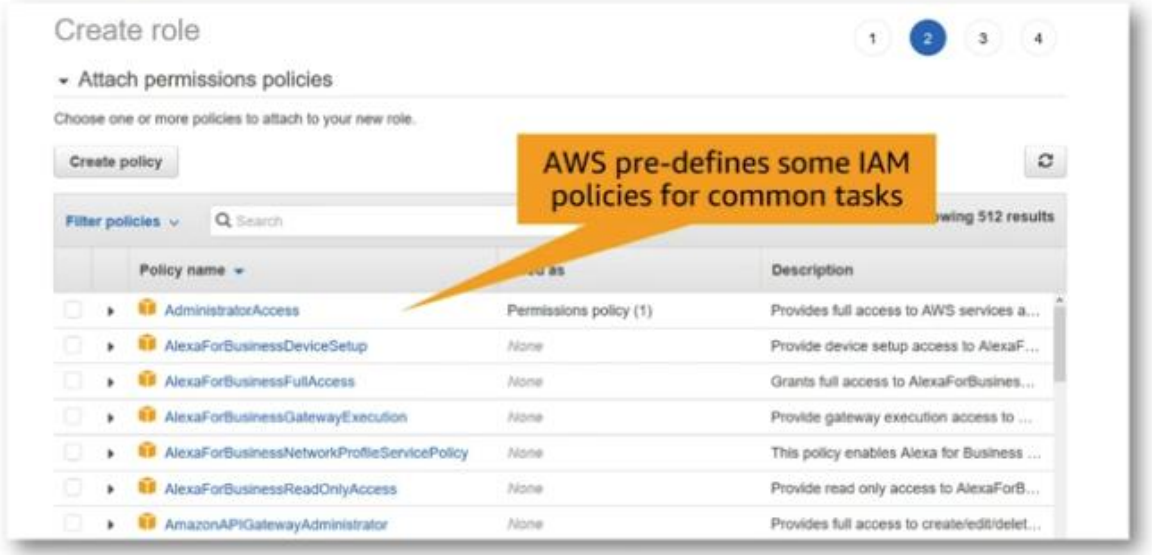
IAM : Identity Authentication Management



IAM Access Keys

- The IAM access keys are cryptographically generated keys representing an AWS account.
- The access key consists of two components: Access Key ID and Secret Access Key.
  - ☐ The Key ID uniquely identifies the credentials, and is considered public knowledge.
  - ☐ The Secret Access Key is used to cryptographically sign all of the requests and is considered private.
  - ☐ Do not share your Secret Access Key with anyone. If compromised it can and must be revoked.

AWS-managed policies for common sets of permissions



IAM Policies

A policy is a JSON document that explicitly lists the permissions.

- Actions—List of specific operations
- Resources—The object being protected
- Effect—Allow or Deny

Example of JSON script:

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": "s3:ListBucket",
    "Resource": "arn:aws:s3:::example_bucket"
  }
}
```

Reading and writing IAM policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "dynamodb:BatchGetItem",
        "dynamodb:GetItem",
        "dynamodb:Query",
      ],
      "Resource": [
        "arn:aws:dynamodb:us-east-2:111122223333:table/MyTableName",
        "arn:aws:dynamodb:us-east-2:111122223333:table/MyTableName/index/*"
      ]
    }
  ]
}
```

In English: Allowed to take specific Amazon DynamoDB actions on a specific table and its indexes

This is an Amazon Resource Name (ARN); All AWS services use them, and they follow this format

Reading and writing IAM policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "dynamodb:*"
      ],
      "Resource": "*"
    }
  ]
}
```

Allow or deny?

What can (or can't) you do?

What can (or can't) you do it to?

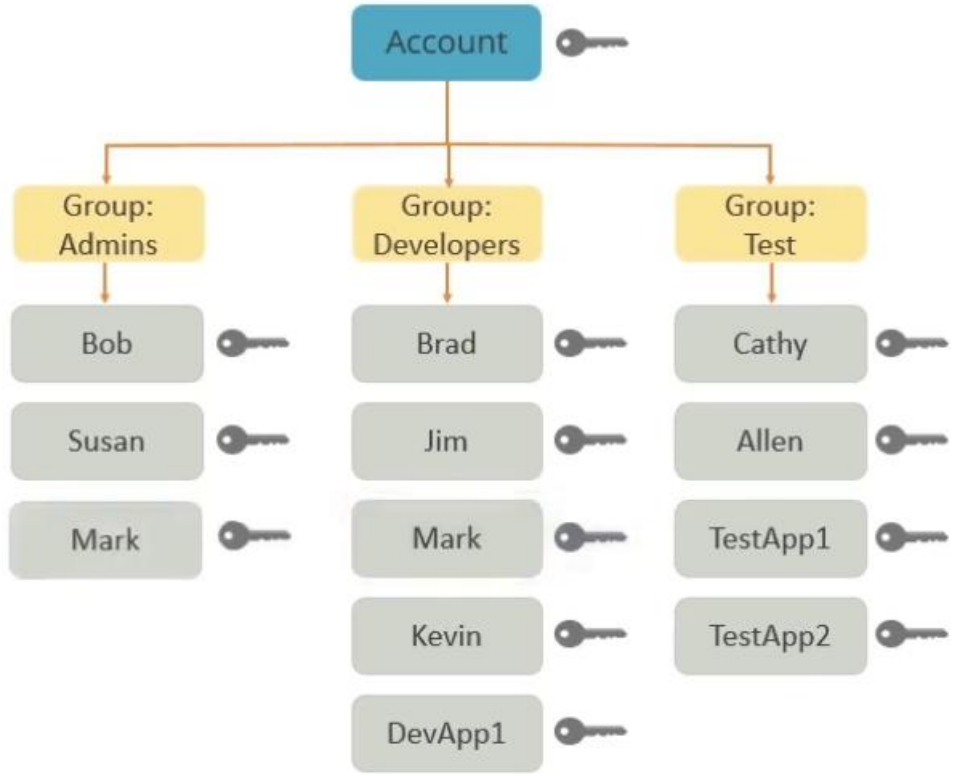
IAM : Identity Authentication Management

IAM Groups

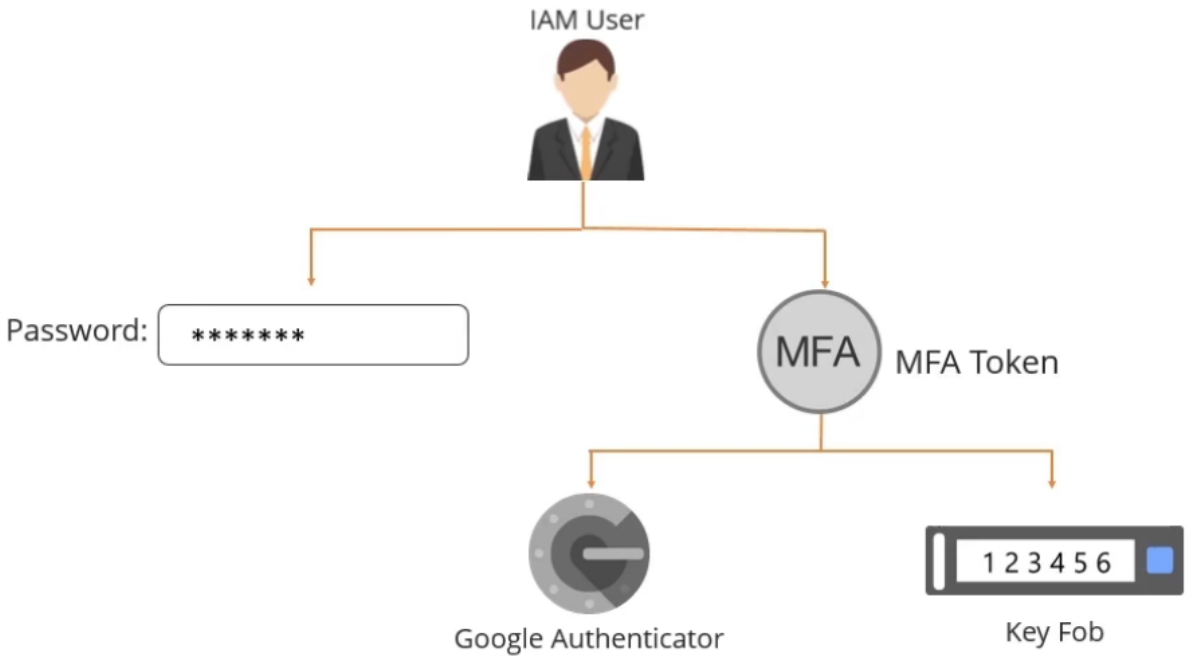
- An IAM group can contain many users, and a user can belong to multiple groups.
- Groups can't be nested—they can contain only users and not other groups.
- There's no default group that automatically includes all users in the AWS account.

IAM Groups—Example

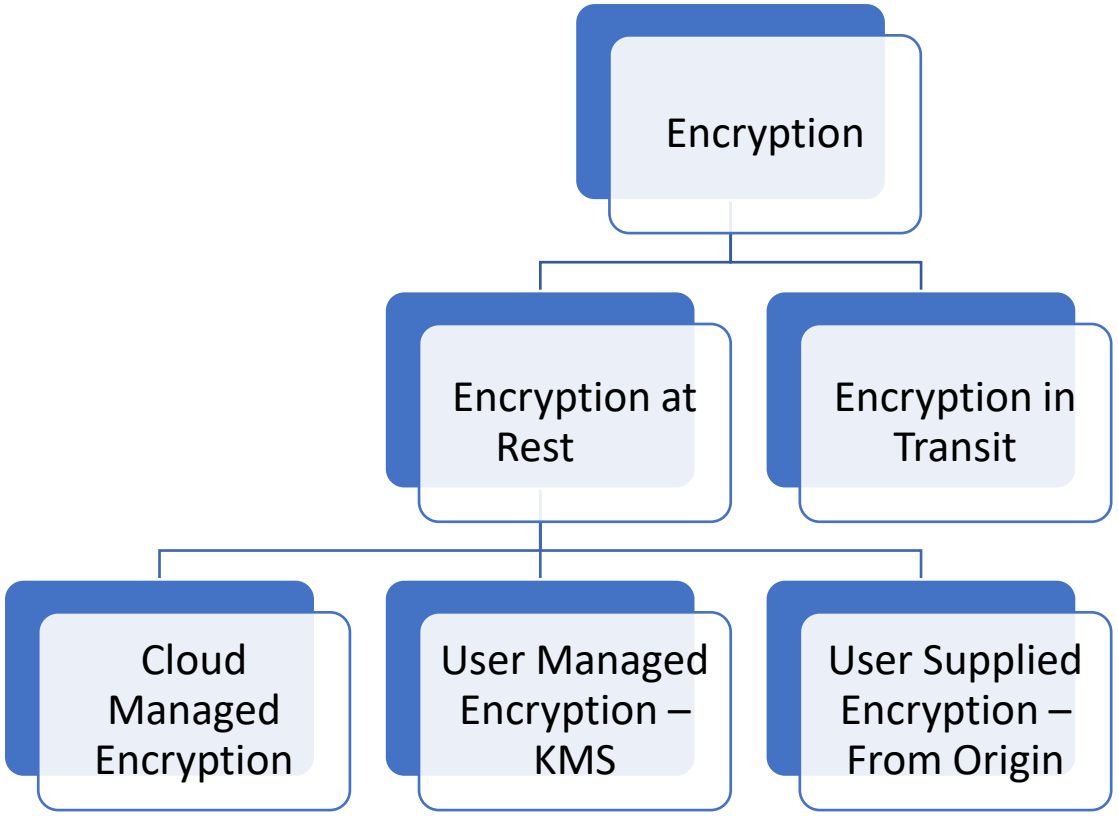
The diagram presents an example of groups created for a small company.

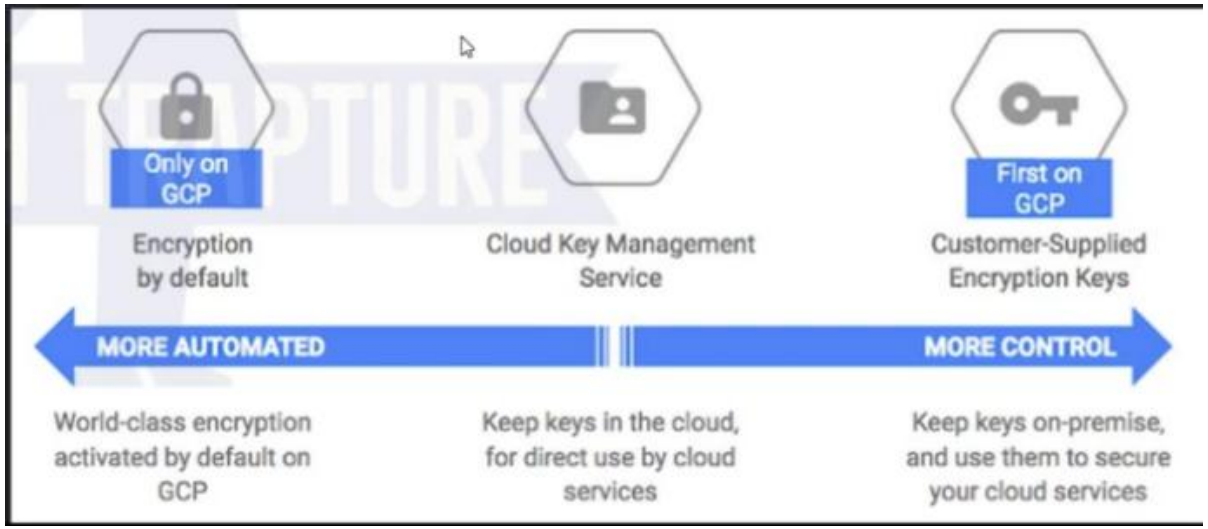


MFA : Multi Factor Authentication



Encryption and KMS (Key Management System)





Encryption and KMS (Key Management System)

Customer can create and manage encryption keys through Cloud KMS.

Steps

- Enabled Cloud KMS API
- Create key ring and key
- Assign Cloud KMS CryptoKey Encrypter/Decrypter. Role to the storage bucket service agent.
- Add encryption method to bucket.

Cloud Storage always encrypts your data on the server side, before it is written to disk, at no additional charge

No additional action required.

Helps to ensure that if data falls into an attacker's hands, the attacker cannot read the data without also having access to the encryption keys.

Customer can choose to provide own keys.

You provide key during each operation.

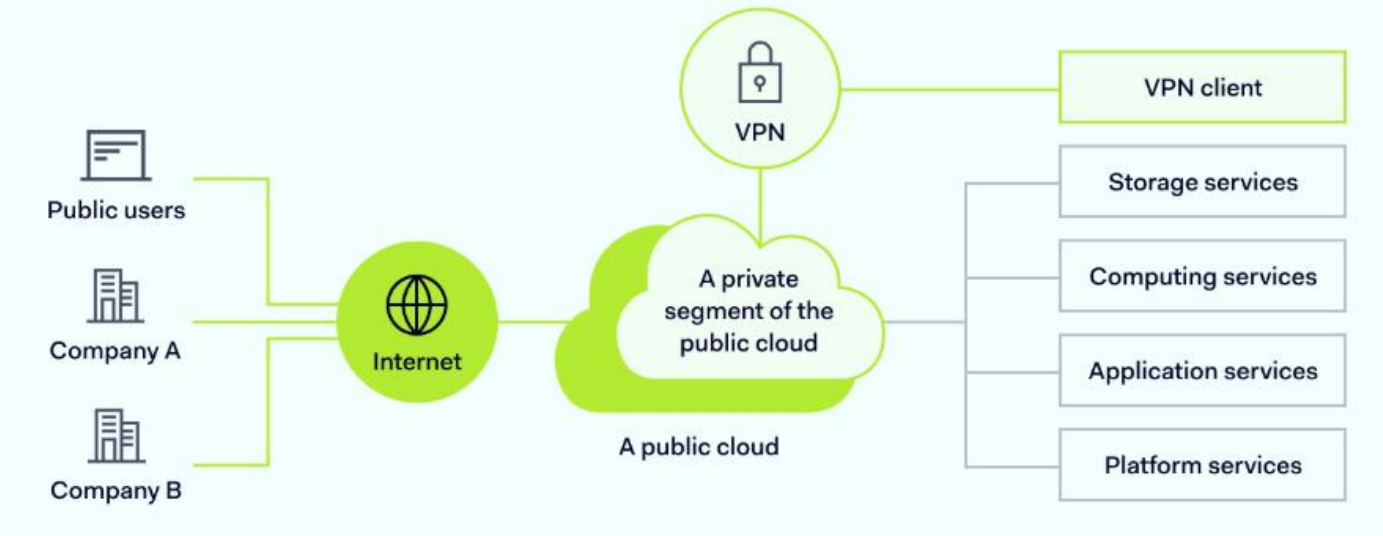
You need to apply encryption on object level and not on bucket level.

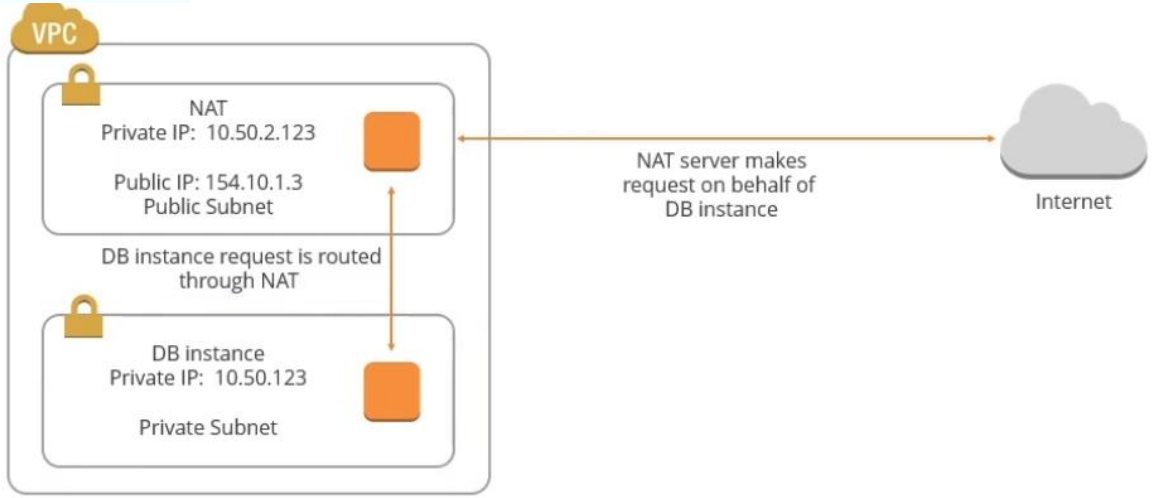
You can not upload/download objects from console if encrypted from CSEK.

Steps

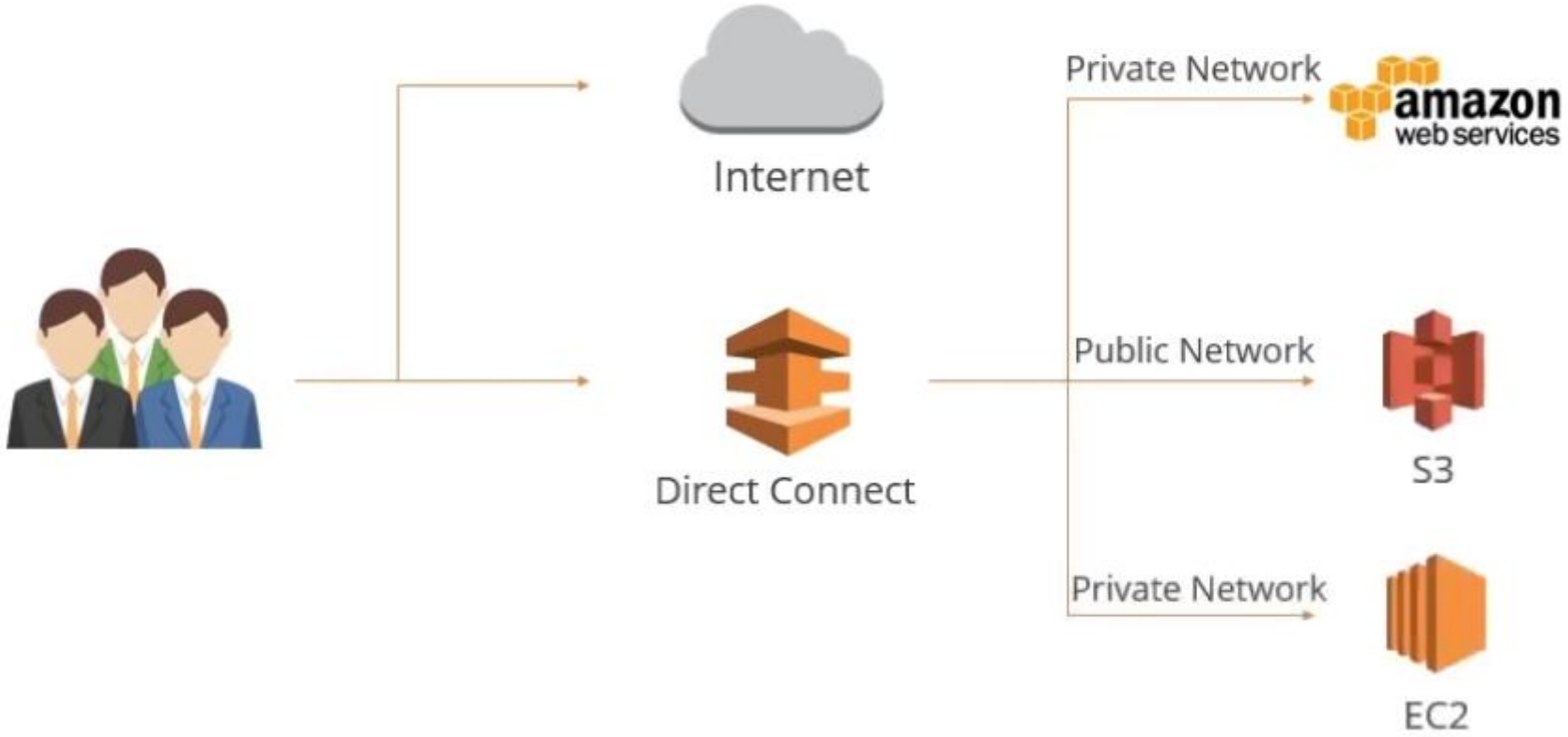
- Generate key
- Update boto config file
- Upload object.

VPC : Virtual Private Cloud





Direct Connect



How To Troubleshoot a Threat in the Cloud?

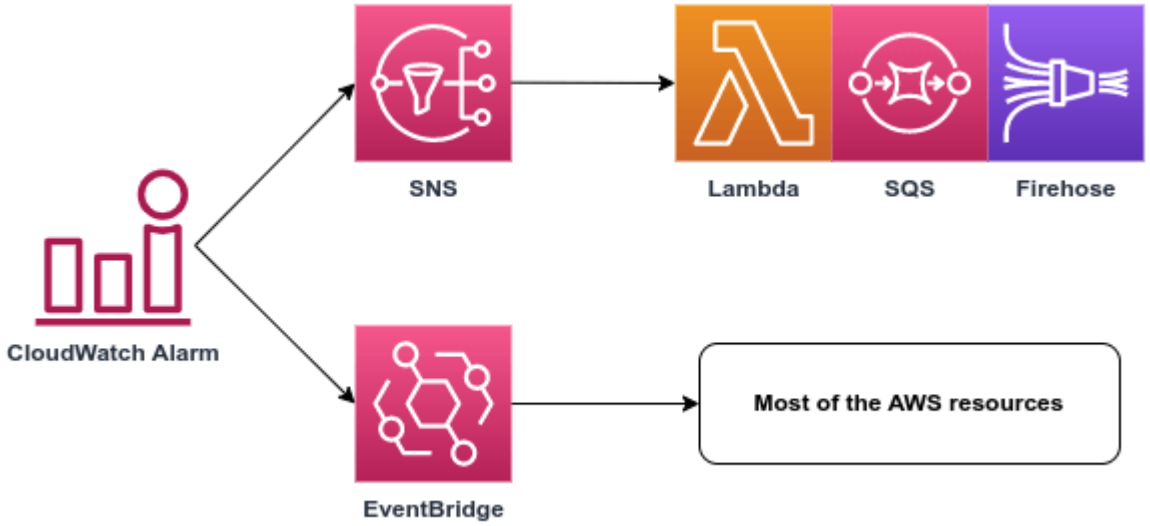
How to Troubleshoot a Threat in the Cloud?



Log Analysis and Filtering

Feature	Amazon CloudWatch/ Azure Monitor/ GCP Cloud Monitoring	AWS CloudTrail/ Azure Activity Log/ Cloud Audit Logs
Purpose	Monitoring & observability	Governance, compliance & API activity tracking
What it collects	Metrics, logs, events, alarms, dashboards	API calls, console actions, IAM activity, resource changes
Type of data	Performance data & operational logs	Audit logs of "who did what, when, from where"
Typical Use	Monitor CPU, memory, network, Lambda logs, alarms, service health	Track user activity, security analysis, detecting unauthorized changes
Data Source	AWS services, applications, OS logs (via agent)	AWS Management Console, SDK, CLI, API calls
Real-Time?	Near real-time metrics & alerts	Near real-time for API audit events
Retention	Customizable	90 days by default (longer if stored in S3)
Security Focus	Operational security	Governance, audit, compliance
Integration	Alarms, dashboards, EventBridge	S3, CloudWatch Logs, Security Hub, GuardDuty
Pricing	Charges for logs, metrics, alarms	Free for 90 days; S3 storage & analysis cost extra
Example Event	"EC2 CPU > 80%"	"IAM user changed a security group rule"
Best For	App monitoring, alerts, troubleshooting	Auditing, forensics, change tracking

Log Analysis and Filtering



Automatic Detecting Misconfiguration

Cloud Platform	Python Library / SDK	Key Features	Common Use Cases
AWS	**boto3**	Full AWS API coverage, resource & client interfaces, high-level abstractions	EC2, S3, IAM, Lambda, CloudWatch automation
	botocore	Low-level API communication layer	Internal use, custom API calls
Azure	**Azure SDK for Python** (modular)	Service-specific packages, identity-based authentication, ARM management	VM operations, Blob storage, Azure AD integration
GCP	**google-cloud-python**	Separate libraries per service, auto-auth, unified approach	BigQuery, Cloud Storage, Compute Engine
OpenStack	**openstacksdk**	Unified API for Nova, Neutron, Keystone, Glance	Provision VMs, networking, image management
	python-openstackclient	CLI + API interactions	Automation, orchestration
VMware	**pyVmomi**	Direct vSphere/vCenter automation	VM operations, snapshotting, datastore operations
Oracle Cloud	**oci-python-sdk**	Full Oracle Cloud API coverage, high security	Compute, storage, identity automation
IBM Cloud	**ibm-cloud-sdk-python**	Supports multiple IBM Cloud services	Storage, ML, compute

Automatic Detecting Misconfiguration

NaolMengistu / AWS-security-scanner Public

Code Issues Pull requests Actions Projects Security Insights

main 1 Branch 0 Tags Go to file Code

NaolMengistu Added more recommendations and auto dark mode 5ff3a4e · 6 months ago 10 Commits

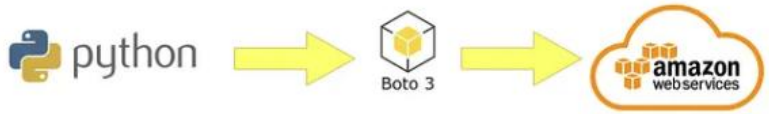
.devcontainer	Added Dev Container Folder	9 months ago
.gitignore	initial commit	9 months ago
README.md	Update README.md	9 months ago
checker.py	Added more recommendations and auto dark mode	6 months ago
requirements.txt	initial commit	9 months ago
streamlit.py	Added more recommendations and auto dark mode	6 months ago

README

AWS Cloud Security Compliance Checker

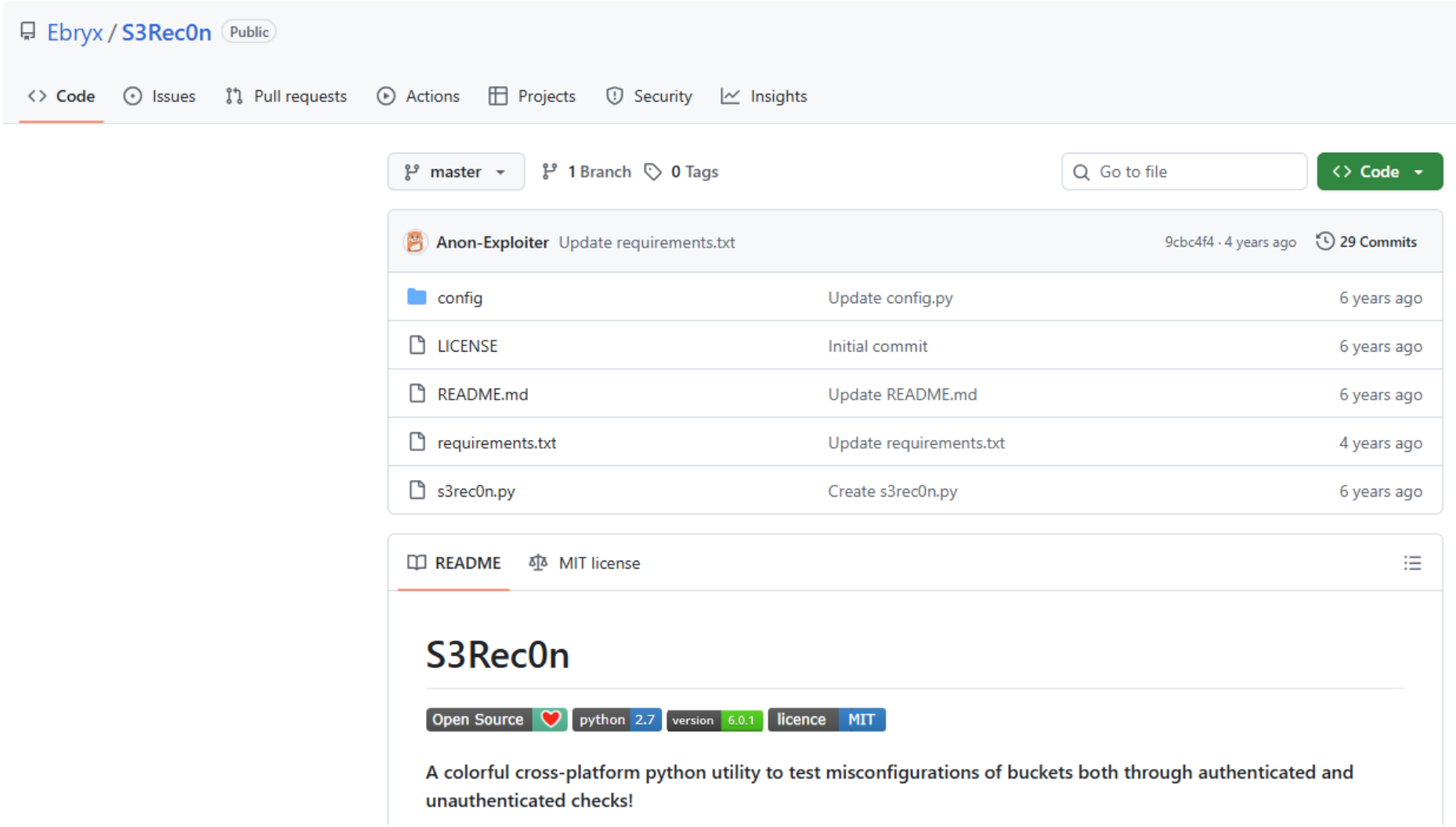
Overview

Welcome to the **AWS Cloud Security Compliance Checker**! This project is designed to assist financial institutions (and any AWS user) in identifying security misconfigurations and ensuring compliance with the **Digital Operational Resilience Act (DORA)**. The tool scans key AWS services, Amazon S3, EC2 Security Groups, IAM Policies, and VPC Configurations, for potential vulnerabilities. Results are presented through an interactive **Streamlit dashboard**, available both locally and deployed on Streamlit Cloud at https://aws-security-scanner.streamlit.app/. Users can also generate a **PDF compliance report** with remediation recommendations.



Automating AWS Tasks with Python and Boto3

Automatic Detecting Misconfiguration



Security Audit

Scout Suite Analytics Compute Database Management Messaging Network Security Storage Regions Filters

Dashboard

Service	Resources	Rules	Findings	Checks
Lambda	0	0	0	0
CloudFormation	0	1	0	0
CloudTrail	0	5	17	18
CloudWatch	0	1	0	0
Directconnect	0	0	0	0
EC2	27	23	83	773
EFS	0	0	0	0
ElastiCache	0	0	0	0
ELB	0	1	0	0
ELBV2	7	3	0	0
EMR	0	0	0	0
IAM	11	32	6	51
RDS	16	7	0	0
RedShift	0	6	0	0
Route53	0	3	0	0
S3	1	19	8	21
SES	0	2	0	0

Scout2 Compute Database Management Messaging Network Security Storage Regions Filters Help

EC2 Dashboard

Default security groups in use
- Security groups checked: 16
- Security groups flagged: 0

Non-empty rulesets for default security groups
- Rulesets checked: 32
- Rulesets flagged: 28

DNS port open to all
- Rules checked: 20
- Rules flagged: 0

MongoDB port open to all
- Rules checked: 20
- Rules flagged: 0

MsSQL port open to all
- Rules checked: 20
- Rules flagged: 0

MySQL port open to all
- Rules checked: 20
- Rules flagged: 0

NFS port open to all
- Rules checked: 20
- Rules flagged: 0

Oracle DB port open to all
- Rules checked: 20
- Rules flagged: 0

PostgreSQL port open to all
- Rules checked: 20
- Rules flagged: 0

RDP port open to all
- Rules checked: 20
- Rules flagged: 0

SMTP port open to all
- Rules checked: 20
- Rules flagged: 0

SSH port open to all
- Rules checked: 20
- Rules flagged: 2

TCP port open to all
- Rules checked: 20
- Rules flagged: 0

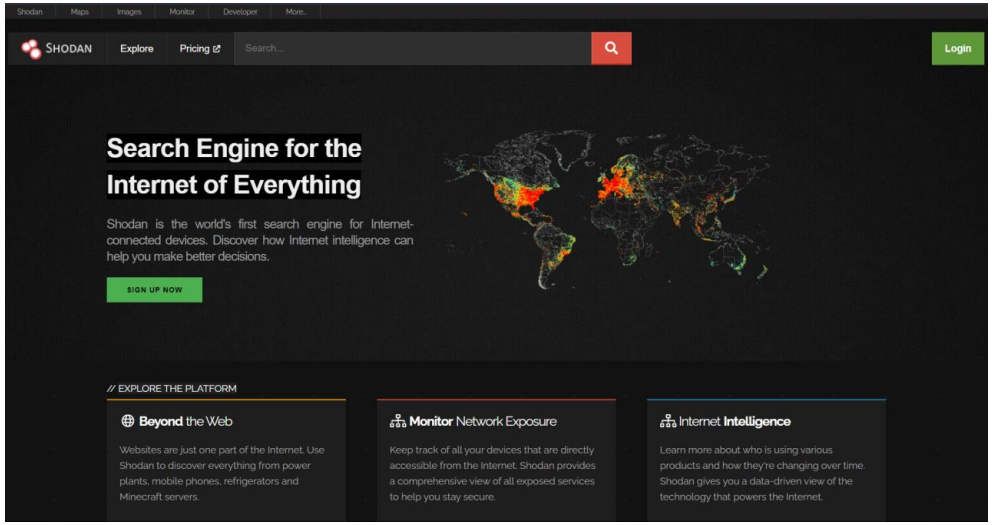
UDP port open to all
- Rules checked: 20
- Rules flagged: 0

All ports open
- Rules checked: 34
- Rules flagged: 14

Shodan : Search Engine

- **What is Shodan?**
- Shodan is a search engine for internet-connected devices. Unlike Google, which indexes websites, Shodan indexes devices, systems, and services exposed to the internet—such as servers, routers, webcams, industrial control systems, and cloud infrastructure.
  - **How Shodan Works:**
  - Continuously scans the internet using specific ports (e.g., 80, 443, 22, 3389).
  - Collects metadata such as:
  - IP addresses
  - Open ports
  - Service banners (e.g., software version info)
  - SSL certificates
  - Server responses
  - Allows users to search using filters like country, OS, port, or even keywords

  (e.g., “MongoDB”, “Amazon AWS”).



Shodan does **not hack or exploit** systems—it simply **indexes what's already exposed** to the public internet. This makes it a valuable **reconnaissance and validation tool** for cloud forensic analysts.

Shodan : Search Engine

- Shodan is useful in cloud forensics in several ways:

1. Asset Discovery:

- Identify cloud services (e.g., AWS EC2, Azure VMs) that are publicly exposed.
- Detect shadow IT or misconfigured cloud services an organization may not be aware of.

2. Vulnerability Assessment:

- Quickly search for cloud-hosted databases (e.g., Elasticsearch, MongoDB) that are misconfigured or unsecured.
- Identify services with outdated software versions prone to exploitation.

3. Incident Response & Forensics:

- In case of a breach, investigators can check historical exposure of the cloud IP via Shodan.
- Determine if a cloud service was publicly exposed at the time of attack.

Use	Description
Cloud asset discovery	Find exposed cloud services like VMs, storage, or APIs
Misconfiguration detection	Identify services with no auth or open ports
Threat hunting	Trace attacker tools (like remote access tools) in the cloud
Incident validation	Validate whether a cloud asset was publicly accessible

Example Use Case: Exposed Elasticsearch Database on AWS

- **Incident:**
- In 2020, security researchers found over 20,000 unsecured Elasticsearch databases exposed via cloud platforms (many on AWS and Azure). These databases had no authentication and were indexed by Shodan.
- **Forensics & Shodan Role:**

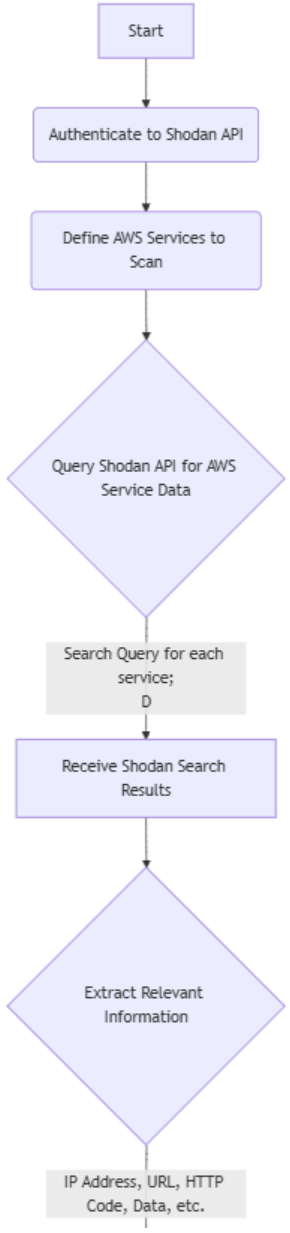
•Investigators used Shodan to locate affected IPs and determine which cloud services were leaking data.

•Cloud logs were then correlated with Shodan timestamps to prove when exposure began, helping in timeline reconstruction.

•Alerts were sent to companies whose data was exposed.

AWS Services Scanning Using Shodan

- Use **Shodan** to discover **publicly exposed AWS services** such as S3 buckets, EC2 instances, RDS databases, Elasticsearch clusters, and more. This helps identify **vulnerable, misconfigured, or unauthorized services** running on Amazon Web Services.



AWS Services Scanning Using Shodan

Scan Type	Forensic Value
Port Scanning	Discover exposed attack surfaces, misconfigurations
Service Detection	Identify services, software versions, and vulnerabilities
DNS Lookup	Track domain-IP mappings, detect abuse or changes
Ping Scan	Determine host status (alive/dead), useful in timeline analysis
WHOIS Lookup	Attribute IPs to owners, detect anonymized attackers
Parcero	Analyze cert metadata, detect AWS resource mismanagement
VirusTotal	Validate indicators of compromise (IoCs) via global threat intel

Cloud Management Tools

AWS - Platform Specific Tools:

- **AWS Management Console** – Web-based interface to manage AWS resources.
- **AWS CloudFormation** – Infrastructure as Code (IaC) for automating resource provisioning.
- **AWS CloudWatch** – Monitoring and alerting service for cloud resources and applications.
- **AWS CloudTrail** – Logging and auditing of API activities for compliance and governance.
- **AWS Trusted Advisor** – Provides recommendations for cost optimization, performance, and security.
- **AWS Systems Manager (SSM)** – Unified interface to manage EC2, on-prem servers, and hybrid resources.

Cloud Management Tools

Multi-Cloud and Hybrid Cloud Management Platforms

These tools manage resources across **multiple cloud providers** and on-premise data centers.

VMware vRealize Suite / Aria Suite

- Automates provisioning, monitoring, and governance across private and public clouds.
- Integrates with AWS, Azure, and GCP.
- Supports self-service portals and policy-based automation.

IBM Cloud Pak for Multicloud Management

- Centralized dashboard for hybrid and multi-cloud operations.
- Offers monitoring, compliance, and cost governance.
- Kubernetes and container management support.

Red Hat CloudForms / Red Hat OpenShift

- Open-source hybrid cloud management and orchestration.
- Integrates with VMware, AWS, OpenStack, and Azure.
- Automates provisioning, lifecycle, and compliance.

Cloud Management Tools

Open Source Cloud Management Tools

OpenStack

- Popular open-source platform for building and managing private and hybrid clouds.
- Manages compute, storage, and networking resources.

Cloudify

- Open-source orchestration and automation platform.
- Supports multi-cloud environments using TOSCA blueprints.

Terraform

- Open-source Infrastructure as Code (IaC) tool.
- Supports AWS, Azure, GCP, and many other providers.

Cloud Management Tools

Cloud Cost and Performance Optimization Tools

CloudHealth (by VMware)
- Multi-cloud cost management, optimization, and governance.
- Tracks usage and provides cost-saving recommendations.

Spot.io (by NetApp)
- Automates cloud cost optimization using AI.
- Efficiently manages spot instances.

Flexera Cloud Management Platform
- Provides visibility, governance, and cost optimization across multiple clouds.

Turbonomic (by IBM)
- Application resource management using AI to optimize performance and cost.

Cloud Management Tools

Cloud Security and Compliance Management Tools

- Prisma Cloud (by Palo Alto Networks)
- Check Point CloudGuard
- Trend Micro Cloud One
- Qualys Cloud Platform

All provide cloud posture management (CSPM), threat detection, compliance reporting, and vulnerability management across multi-cloud environments.

Cloud Security: Best Practices

